



WAF MINI HACKATHON 2026

Build Lightweight Security Gateway for Real-World Abuse Protection

THỂ LỆ CUỘC THI CHÍNH THỨC

Tháng 4 – Tháng 5, 2026

Cuộc thi toàn công ty — Mở rộng cho toàn bộ khối Tech
~400 Engineers · Tối thiểu 3 thành viên/Đội

GIẢI NHẤT: \$30,000 USD | GIẢI NHÌ: \$20,000 USD | GIẢI BA: \$10,000 USD

3 GIẢI KHUYẾN KHÍCH: \$5,000 USD

1. MỤC TIÊU CUỘC THI

WAF Mini Hackathon 2026 là cuộc thi công nghệ nội bộ quy mô lớn của toàn công ty, mở rộng cho toàn bộ khối Tech tham gia, nhằm các mục tiêu chiến lược sau:

- Xây dựng Internal WAF + Anti-Abuse Gateway thực chiến, có khả năng bảo vệ hệ thống công ty trước các mối đe dọa thực tế (bot, fraud, DDoS, relay attack...).
- Phát hiện, bồi dưỡng và công nhận các tài năng Security Engineer & Future Tech Leaders trong công ty.
- Tạo ra nền tảng bảo mật cốt lõi có thể triển khai vào production ngay sau khi cuộc thi kết thúc.

2. ĐỐI TƯỢNG & QUY MÔ

Thông số	Chi tiết
Đối tượng tham gia	Toàn bộ nhân viên khối Tech
Hình thức	Thi theo đội nhóm
Thành viên/đội	Tối thiểu 3 người — không giới hạn tối đa
Ngôn ngữ bắt buộc	Rust cho phần Core(bắt buộc hoàn toàn), control plane, dashboard .. (có thể sử dụng nodejs hoặc bất kỳ ngôn ngữ nào)
Thời gian tổ chức	Tháng 4 – Tháng 5 / 2026

3. LỊCH TRÌNH CUỘC THI

Giai đoạn	Thời gian	Nội dung chính
Kick-off & Training	Tuần 1-2	Công bố thể lệ chính thức · Chọn đội · Cấp sandbox environment
Development Sprint	Tuần 3-4-5	Build hệ thống
Hardening & Testing	Tuần 6	Tối ưu & kiểm tra · Red Team Dry Run · Code Freeze cuối tuần · Nộp bài chính thức
Attack Battle	Tuần 7	Demo 10 phút/đội · Attack Battle 45 phút · Chấm điểm realtime

4. NHIỆM VỤ CUỘC THI

Mỗi đội phải phát triển một Mini WAF (Web Application Firewall) / Security Gateway hoàn chỉnh, đứng trước và bảo vệ **TOÀN BỘ** website mục tiêu — không chỉ một số endpoint riêng lẻ. WAF hoạt động như một full reverse proxy: mọi request từ internet đều đi qua WAF trước khi đến backend, mọi response từ backend đều đi qua WAF trước khi trả về client.

Lý do: Attacker không chỉ attack /login — chúng scan toàn bộ site, tìm /admin, /api/, static assets có thể leak info, rồi mới khai thác. WAF chỉ bảo vệ một số endpoint cụ thể sẽ bị bypass dễ dàng qua các route khác.*

Kiến trúc triển khai

Internet → [WAF / Security Gateway] → Backend Application

WAF phải trong suốt với backend — backend không cần biết WAF tồn tại, không cần thay đổi code.

Policy theo tầng (Tiered Protection Policy)

WAF áp dụng policy bảo vệ khác nhau cho từng nhóm route, từ nghiêm ngặt nhất đến cơ bản nhất:

Tier	Route pattern	Policy áp dụng	Ghi chú
CRITICAL	/login /otp /deposit /withdrawal	Full stack: rate limit per-user, device fingerprint, behavioral check, transaction velocity, fail-close, canary	Fail-close khi WAF lỗi — deny all
HIGH	/game/* /api/* /user/*	DDoS protection, rate limit per-IP & per-session, OWASP detection, smart caching, bot filter	Fail-open cho traffic bình thường
MEDIUM	/static/* /assets/* /public/*	Rate limit cơ bản, path traversal detect, cache aggressively	High throughput — latency ưu tiên
CATCH-ALL	Mọi route còn lại /**	Baseline: SQLi/XSS detect, rate limit, block known-bad IP, log tất cả	Không bỏ sót route nào

Tất cả traffic — bất kể tier — đều được: inspect inbound & outbound, ghi audit log, tính risk score, và áp dụng global blacklist.

Hệ thống phải tự động phát hiện và phòng thủ trước mọi loại tấn công do Red Team thực hiện vào bất kỳ route nào của website.

5. YÊU CẦU KỸ THUẬT

5.1 Yêu cầu Core (BẮT BUỘC)

Ngôn ngữ lập trình: Rust (bắt buộc hoàn toàn — không exception)

Output: Single binary — không phụ thuộc runtime, không cần Docker

Lệnh khởi chạy:

```
./waf run
```

Mode: Reverse Proxy — bidirectional HTTP/HTTPS inspection (inbound & outbound)

Performance SLA: p99 latency overhead <= 5ms | throughput >= 5,000 req/s baseline

5.2 Chức năng cốt lõi (BẮT BUỘC)

#	Chức năng	Mô tả kỹ thuật
01	Rule Engine	Match theo IP, Path, Header, Payload, Cookie — hỗ trợ regex, wildcard, exact match, logical AND/OR

#	Chức năng	Mô tả kỹ thuật
02	Rate Limiting (per-user)	Sliding window per IP Và per user-session — không chỉ per IP. Token bucket cho burst control
03	DDoS Protection	Burst detection + auto block + configurable threshold per route tier. Fail-close mode cho CRITICAL tier, fail-open cho MEDIUM/CATCH-ALL tier
04	Challenge Engine	JS Challenge, Proof-of-Work. Adaptive: Allow / Challenge / Block dựa trên risk score tích lũy
05	Relay & Proxy Detection	Proxy chain detection, X-Forwarded-For chain validation, abnormal header patterns, ASN classification (residential vs datacenter vs Tor)
06	Whitelist + Blacklist	IP & FQDN whitelist. Threat intel blacklist load từ file lúc startup (Tor exit list, bad ASN). Auto risk boost cho known-bad IPs
07	Smart Caching	Không cache CRITICAL tier routes. Cache aggressively cho MEDIUM tier (/static, /assets). Cache-aware với TTL configurable per route pattern
08	Device Fingerprinting	Tạo device ID bền vững từ: TLS fingerprint (JA3/JA4), HTTP/2 settings, User-Agent entropy, Accept-Encoding pattern. Phát hiện cùng device đổi IP để bypass block
09	Behavioral Anomaly Detection	Phát hiện: request timing quá đều (bot), zero-depth session (thẳng vào CRITICAL route không qua homepage), thiếu Referer trên sensitive routes, inter-request interval < 50ms
10	Transaction Velocity & Sequence	Per-user cross-endpoint tracking: Login→OTP→Deposit trong N giây. Withdrawal velocity check sau deposit. Rapid limit-change pattern detection

5.3 Attack Detection Coverage (BẮT BUỘC — OWASP Top 5 minimum)

Đây là tiêu chí tối thiểu để hệ thống được coi là 'WAF' thực sự.

Attack Vector	Yêu cầu detection
SQL Injection (SQLi)	Classic, blind, time-based, UNION-based. Detect trong URL params, headers, JSON body
Cross-Site Scripting (XSS)	Reflected & stored XSS payload detect. Script injection trong query string, form data, JSON
Path Traversal	../ sequences, URL-encoded variants (%2e%2e), detect trong URL path & query params
SSRF Attempt	Request tới internal IP ranges (10.x, 172.16.x, 192.168.x, 169.254.x), metadata endpoint
HTTP Header Injection	Host header injection, response splitting (CRLF injection), X-Forwarded-For spoofing
Brute Force / Credential Stuffing	Per-user failed login counter, password spraying pattern (nhiều user khác nhau từ cùng IP)
Error Scanning / Recon	Rapid 4xx/5xx pattern, endpoint enumeration, option method abuse
Request Body Abuse	Malformed JSON, oversized payload (> configurable limit), deeply nested object, content-type mismatch

5.4 Hệ thống Rule linh hoạt (BẮT BUỘC)

- Hỗ trợ thêm/sửa/xóa rule KHÔNG cần rebuild binary — hot-reload bắt buộc
- Rule format: YAML hoặc TOML. Rule phải có: condition (match), action (allow/block/challenge/rate-limit), risk_score_delta
- Rule scope: global (toàn website), per-tier (CRITICAL/HIGH/MEDIUM/CATCH-ALL), per-route-pattern, per-IP, per-user-session, per-device-fingerprint
- Rule priority: numeric priority để resolve conflict khi nhiều rule match

5.5 Challenge & Risk Engine (BẮT BUỘC)

- Risk score tích lũy per {IP + device fingerprint + session} — không reset sau mỗi request
- Risk score tăng khi: rule match, failed challenge, behavioral anomaly, ASN suspicious, device fingerprint conflict
- Risk score giảm khi: challenge thành công, sustained normal behavior over time window
- Decision threshold configurable: score < 30 = Allow, 30-70 = Challenge, > 70 = Block
- Canary Endpoint / Honeypot: deploy decoy paths (/admin-test, /api-debug). Bất kỳ request nào hit = auto set risk score = MAX, block IP ngay

5.6 Realtime Dashboard (BẮT BUỘC)

- Live feed: request log theo thời gian thực với request ID, timestamp (ms), risk score, action, rule triggered
- Attack visualization: attack type distribution chart, top attacker IPs, endpoint heatmap
- Hot config: cập nhật rule, toggle action (block/challenge/allow), adjust threshold — KHÔNG restart service
- Structured audit log: JSON format, append-only, có thể ingest vào SIEM. Mỗi entry có: request_id, ts_ms, ip, device_fp, risk_score, rule_id, action

5.7 Response Filtering & Outbound Protection (BẮT BUỘC)

WAF phải inspect cả response trước khi trả về client. Đây là yêu cầu bổ sung giúp ngăn rò rỉ thông tin nội bộ ra ngoài.

- Block response chứa stack trace, internal IP, API key, hoặc verbose error message (5xx với body > configurable size)
- Mask/redact sensitive fields trong response JSON (configurable field list: card_number, bank_account, ...)
- Detect và block accidental PII leak trong response headers (X-Debug, X-Internal-*)

5.8 Graceful Degradation (BẮT BUỘC)

Attack Battle sẽ bao gồm kịch bản DDoS nhắm vào chính WAF. Behavior khi WAF bị stress phải được define rõ.

- Fail-close mode cho CRITICAL tier (routes nhạy cảm): từ chối tất cả traffic nếu WAF internal error — an toàn hơn là để traffic pass-through
- Fail-open mode cho MEDIUM & CATCH-ALL tier: allow-through nếu WAF overloaded, ghi log warning để review sau
- Config fail-close hay fail-open phải configurable per route tier trong rule file — không hardcode
- Circuit breaker cho upstream backend: nếu backend không respond, WAF trả 503 thay vì hang connection

5.9 Tính năng nâng cao (BONUS — Điểm cộng)

Tính năng	Độ khó	Mô tả
HTTPS / TLS termination	Trung bình	TLS termination & mTLS support, configurable cipher suites
Geographic Restriction	Trung bình	GeoIP lookup (MaxMind lite DB), block/challenge từ restricted jurisdictions, detect VPN bypass geo
IP Reputation Feed	Thấp	Load Tor exit list + bad ASN list từ file lúc startup, refresh định kỳ. Auto risk boost
Multi-region Deployment	Cao	waf deploy --region=sg,eu,us. Config sync across regions
Zero-downtime Config Sync	Cao	Rolling config update không down service, config versioning
Auto Scaling	Cao	Horizontal scale theo traffic, shared state via Redis/etcd
Behavioral ML Scoring	Rất cao	Lightweight ML model để classify bot vs human dựa trên request sequence pattern

6. TIÊU CHÍ CHẤM ĐIỂM (Tổng: 120 điểm)

Tiêu chí	Nội dung đánh giá chi tiết	Điểm
Security Effectiveness	Detect rate & false positive rate dưới Attack Battle thực chiến. Coverage OWASP Top 5: SQLi, XSS, Path Traversal, SSRF, Header Injection. Device fingerprinting accuracy. Behavioral anomaly detection. Canary endpoint hoạt động.	40 / 120
Performance	p99 latency overhead <= 5ms. Throughput >= 5,000 req/s. Memory footprint. Behavior under load khi bị DDoS	20 / 120
Intelligence & Adaptiveness	Risk score accuracy (per user + device + session). Transaction velocity & sequence detection. Graceful degradation khi bị overload. Fail-close/fail-open behavior đúng per endpoint.	20 / 120
Architecture & Code Quality	Rust code quality, idiomatic patterns, error handling, documentation, test coverage	15 / 120
Extensibility	Rule system: hot-reload, per-scope (IP/user/session/device), priority resolution. Plugin-ready architecture. Response filtering configurable.	10 / 120
Dashboard UI/UX & Realtime Config	Live request feed với structured log. Attack visualization. Hot config update. Audit log JSON format.	10 / 120

Tiêu chí	Nội dung đánh giá chi tiết	Điểm
Deployment & Operability	Single binary, one-command startup, fail behavior documented, circuit breaker upstream	5 / 120

Lưu ý: Security Effectiveness chiếm 33% tổng điểm — đây là tiêu chí quan trọng nhất, đánh giá toàn diện từ OWASP coverage đến các threats đặc thù của hệ thống công ty (device fingerprinting, behavioral anomaly, transaction sequence).

7. ATTACK BATTLE

Quy trình Attack Battle

- Red Team do Ban tổ chức chỉ định — bao gồm Security Leads và external security experts.
- **Mỗi đội lần lượt chịu tấn công trong 45 phút. Red Team tấn công vào BẤT KỲ route nào của website — không chỉ các endpoint nhạy cảm.**
- **Hệ thống phải TỰ ĐỘNG phát hiện và phòng thủ — TUYỆT ĐỐI CẤM can thiệp thủ công.**
- Ban giám khảo theo dõi realtime dashboard của từng đội trong suốt Attack Battle.
- **Red Team sẽ bao gồm kịch bản DDoS nhắm thẳng vào WAF để test graceful degradation behavior.**

Kịch bản tấn công (mở rộng)

#	Attack Vector	Kỹ thuật tấn công
01	DDoS Layer 4 & 7	TCP/UDP flooding, HTTP flood, Slowloris, RUDY attack. Bao gồm kịch bản DDoS nhắm vào WAF để test graceful degradation
02	Bot Login & Credential Stuffing	Brute force login, password spraying từ nhiều IP khác nhau, distributed credential stuffing với IP rotation
03	Relay & Proxy Attack	Proxy chain injection, abnormal X-Forwarded-For, VPN/Tor exit node, datacenter IP → /login attack
04	Device Fingerprint Evasion	Thay đổi TLS fingerprint, rotate User-Agent, giả mạo residential IP trong khi dùng cùng một thiết bị để multi-account
05	Behavioral Bypass	Zero-depth session attack (thẳng vào /deposit), perfectly-timed bot request, giả mạo Referer header
06	Transaction Fraud Pattern	Login→Deposit nhanh (<5s), withdrawal ngay sau deposit, rapid limit-change + withdrawal pattern
07	OWASP Injection	SQLi variants (blind, time-based), XSS payload trong JSON body, SSRF tới internal IP, path traversal
08	Canary / Recon Scan	Endpoint enumeration, honeypot endpoint scan, OPTIONS method abuse, error response harvesting

8. GIẢI THƯỞNG

Giải thưởng chính thức

Hạng	Giải thưởng
 Nhất	\$30,000 USD
 Nhì	\$20,000 USD
 Ba	\$10,000 USD
 Khuyến khích x3	\$5,000 USD

9. QUY ĐỊNH BẮT BUỘC & NGHIÊM CẤM

Bắt buộc

- WAF phải đứng trước và bảo vệ TOÀN BỘ website — không được chỉ proxy một số route nhất định và bỏ qua phần còn lại.
- CRITICAL tier (login, otp, deposit, withdrawal) phải được bảo vệ nghiêm ngặt nhất với đầy đủ policy theo thể lệ.
- Phát hiện các pattern bất thường xuyên route: Login → Deposit nhanh, multi-IP/session, zero-depth session vào CRITICAL routes.
- Demo phải dùng real traffic, WAF chạy thực tế trước toàn bộ backend — không được dùng mock response cứng.
- Hệ thống phải tự phòng thủ trong Attack Battle, không được có người ngồi điều khiển.

Nghiêm cấm

- ✗ Sử dụng dữ liệu giả hoặc demo fake — BỊ LOẠI NGAY LẬP TỨC.
- ✗ Hardcode rule chỉ để vượt qua test case cụ thể — BỊ LOẠI NGAY LẬP TỨC.
- ✗ Can thiệp thủ công vào hệ thống trong vòng Attack Battle — BỊ LOẠI NGAY LẬP TỨC.
- ✗ Tấn công sandbox của đội khác trong giai đoạn Development.

Vi phạm bất kỳ quy định nào trong phần Nghiêm cấm sẽ dẫn đến loại trực tiếp khỏi cuộc thi mà không cần giải thích thêm.

10. REGISTRATION & PROCESS

Bước	Hành động	Chi tiết
01	Đăng ký cá nhân	Điền form nội bộ: tên, level, stack, role mong muốn. Deadline: Cuối Tuần 2.
02	Lập đội	Tự lập đội hoặc được Ban tổ chức match theo skill set. Tối thiểu 3 thành viên/đội.
03	Submit thông tin đội	Team Lead nộp: tên đội, danh sách thành viên. Ban tổ chức confirm & cấp sandbox.
04	Development & Check-in	Build hệ thống.

Bước	Hành động	Chi tiết
05	Code Freeze & Nộp bài	Cuối Tuần 5: nộp repo + binary (amd64 Linux) + README. Không commit sau freeze.
06	Pre-final Verification	Ban tổ chức verify: ./waf run chạy được, connect test target, dashboard accessible.
07	Final Demo + Attack Battle	Demo 10 phút/đội. Attack Battle 45 phút. Chấm điểm theo rubric chính thức.
08	Trao giải & Post-hackathon	Trao giải. Top 3 onboard Core Security Team. HR xử lý promotion trong 2 tuần.

Ban giám khảo

- CEO
- CTO
- Tech Manager
- Head of Security
- Red Team (chấm điểm Attack Battle)